SECURE UNIVERSITY ACADEMIC RECORDS SYSTEM

نظام السجلات الأكاديمية الجامعي الآمن

المرحلة الأولى: التحليل والتصميم

MILESTONE 1 — ANALYSIS & DESIGN

Information and Database Security (906313)

وثيقة المتطلبات والتصميم وتحليل التهديدات

1. وصف المشروع

نظام ويب لإدارة بيانات الطلبة والمحاضرين والمقررات والشُعب والتسجيلات والعلامات. يهدف إلى حماية السجلات الأكاديمية وضمان وصول كل مستخدم إلى البيانات والوظائف المسموح بها وفق دوره.

التقنيات المقترحة

الجزء	التقنية	الوظيفة
Database	Oracle AI Database Free 26ai	تخزين البيانات والقيود وضوابط الوصول.
Backend	JDK 21, Spring Boot 3.x, Spring Security, Maven	المصادقة والصلاحيات وقواعد العمل.
Frontend	React, Vite, Node.js LTS	واجهات المستخدم.
Version Control	Git	إدارة الملفات والإصدارات.

2. Functional Requirements

ID	المتطلب
FR01	تسجيل دخول وخروج آمن، وإنهاء الجلسة عند انتهاء صلاحيتها.
FR02	الطالب يشاهد بياناته وتسجيلاته وعلاماته المنشورة فقط.
FR03	المحاضر يشاهد الشُعب المسندة إليه والطلبة المسجلين فيها فقط.
FR04	المحاضر يدخل العلامات أو يعدلها وفق حالة الشعبة.
FR05	المسجل يدير بيانات الطلبة والمقررات والشُعب والتسجيلات حسب صلاحياته.
FR06	تعديل العلامة بعد الإغلاق يتطلب طلبًا وموافقة وسببًا وتسجيل العملية.
FR07	المدقق الأمني يقرأ سجلات عمليات العلامات ومحاولات الدخول المرفوضة فقط.
FR08	بحث وترتيب وتصفية حسب الدور مع حماية المدخلات.
FR09	رسائل الخطأ لا تكشف تفاصيل Database أو SQL أو كلمات المرور.
FR10	إعادة بناء النظام من README وملفات SQL مرتبة.
FR11	واجهة بسيطة؛ التصميم لا يحل محل متطلبات الأمان.
FR12	عزل بيئة اختبار SQL Injection عن قاعدة البيانات الفعلية.

3. User Roles & Business Rules

Role	الصلاحيات	القيود
Student	مشاهدة الملف الشخصي والتسجيلات والعلامات المنشورة الخاصة به.	لا يشاهد بيانات غيره ولا يعدل العلامات.
Lecturer	مشاهدة الشُعب المسندة إليه وإدخال العلامات أثناء فتح الشعبة.	لا يعدل شعبة محاضر آخر ولا يتجاوز الإغلاق.
Registrar	إدارة السجلات الأكاديمية ومعالجة طلبات التعديل حسب الإجراء.	توثيق سبب التعديل وعدم حذف سجلات التدقيق.
Security Auditor	قراءة Audit Logs وSecurity Events المسموح بها.	Read-only.

قواعد العمل

- يجب أن يتحقق Backend من الصلاحيات في كل طلب محمي.
- تُخزّن كلمات المرور باستخدام BCrypt أو Argon2.
- يُسجل كل تعديل علامة مع هوية المنفذ والوقت والقيمة القديمة والجديدة والسبب.
- تستخدم الاستعلامات Parameterized Queries.
- يستخدم التطبيق حساب قاعدة بيانات محدود الصلاحيات باسم APP_USER.

4. Database Design — Logical ERD

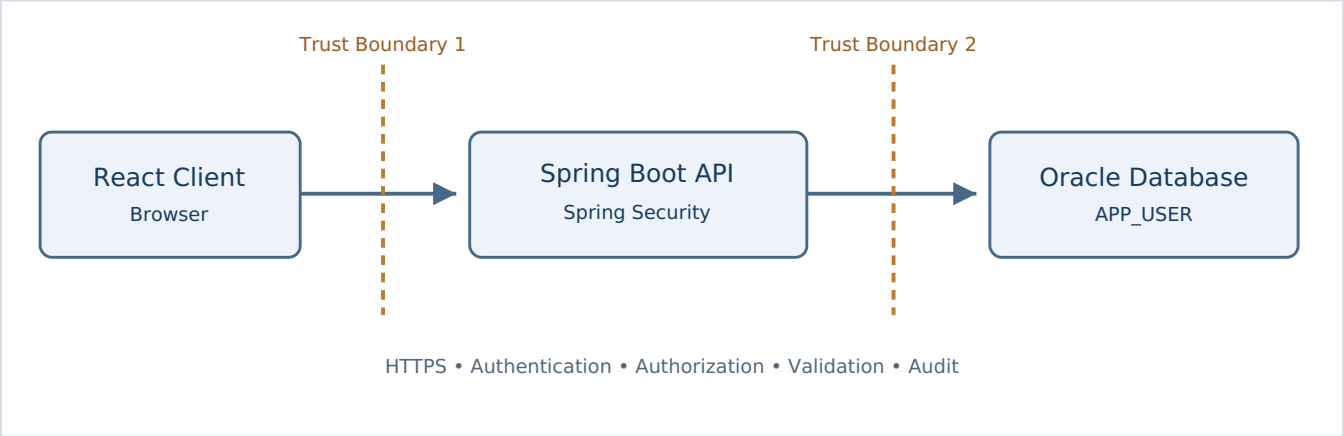
PK: Primary Key، FK: Foreign Key.

Table	الحقول الرئيسية
APP_USERS	user_id NUMBER (PK), username VARCHAR2(80) UNIQUE, password_hash VARCHAR2(255), app_role VARCHAR2(30), active CHAR(1)
STUDENTS	student_id NUMBER (PK), user_id NUMBER (FK, UNIQUE), student_no VARCHAR2(30) UNIQUE, full_name VARCHAR2(150), national_id VARCHAR2(30), dob DATE, phone VARCHAR2(30)
LECTURERS	lecturer_id NUMBER (PK), user_id NUMBER (FK, UNIQUE), staff_no VARCHAR2(30) UNIQUE, full_name VARCHAR2(150), department VARCHAR2(100)
COURSES	course_id NUMBER (PK), code VARCHAR2(20) UNIQUE, title VARCHAR2(150), credit_hours NUMBER(2)
COURSE_OFFERINGS	offering_id NUMBER (PK), course_id NUMBER (FK), lecturer_id NUMBER (FK), term VARCHAR2(30), section_code VARCHAR2(20), status VARCHAR2(20)
ENROLLMENTS	enrollment_id NUMBER (PK), student_id NUMBER (FK), offering_id NUMBER (FK), grade NUMBER(5,2), enrollment_status VARCHAR2(20)
GRADE_AUDIT	event_id NUMBER (PK), enrollment_id NUMBER (FK), actor_user_id NUMBER, old_grade NUMBER(5,2), new_grade NUMBER(5,2), changed_at TIMESTAMP, reason VARCHAR2(500)
SECURITY_EVENTS	event_id NUMBER (PK), actor_user_id NUMBER, event_type VARCHAR2(50), outcome VARCHAR2(20), event_time TIMESTAMP

العلاقات والقيود

- APP_USERS يرتبط اختياريًا بسجل واحد في STUDENTS أو LECTURERS.
- المقرر الواحد له عدة شعب؛ والمحاضر يمكن أن يُسند إليه عدة شعب.
- العلاقة بين الطلبة والشُعب متعدد إلى متعدد من خلال ENROLLMENTS.
- كل تسجيل يمكن أن يرتبط بعدة سجلات GRADE_AUDIT.
- تُستخدم قيود PRIMARY KEY, FOREIGN KEY, NOT NULL, UNIQUE, CHECK. تكون العلامة فارغة أو بين 0 و100، ويُمنع حذف سجلات التدقيق تلقائيًا.

5. System Architecture & Data Flow



يتكون النظام من واجهة React، وخادم Spring Boot REST API، وقاعدة بيانات Oracle. يتولى الخادم التحقق من الهوية والصلاحيات والمدخلات، ويتصل بقاعدة البيانات عبر حساب محدود الصلاحيات.

حدود الثقة — Trust Boundaries

1. بين Browser وApplication Server: لا تُوثق مدخلات المتصفح، ويجري التحقق منها في الخادم.
2. بين Application Server وDatabase: اتصال محمي وحساب محدود، دون وصول مباشر غير مقيد للجداول.

تدفق البيانات — DFD

العملية	التدفق
Login	التحقق من كلمة المرور وحالة الحساب ثم إنشاء Secure Session.
Read Records	فحص الدور وإرجاع السجلات المسموح بها فقط.
Grade Update	التحقق من مسؤولية المحاضر وحالة الشعبة، ثم حفظ العلامة وسجل التدقيق ضمن Transaction واحدة.
Audit	قراءة السجلات المصرح بها دون تعديلها.
Backup & Restore	استعادة نسخة في بيئة اختبار منفصلة وإخفاء البيانات الحساسة.

6. STRIDE Threat Model

التقدير من 1 (منخفض) إلى 3 (مرتفع). درجة الخطورة = Likelihood × Impact.

Threat	مثال	L	I	Control
Spoofing	استخدام حساب مسروق.	2	3	BCrypt/Argon2، تحديد محاولات الدخول والجلسات الآمنة.
Tampering	تغيير studentId للوصول لسجل آخر.	3	3	فحص الصلاحيات وRBAC وVPD.
Repudiation	إنكار تعديل علامة.	2	3	GRADE_AUDIT محمي يسجل المنفذ والوقت والقيم والسبب.
Information Disclosure	مشاهدة علامات طالب آخر.	3	3	RBAC, VPD, Least Privilege.
Denial of Service	طلبات متكررة تستهلك الموارد.	2	2	Rate Limits, Timeouts, Monitoring.
Elevation of Privilege	محاضر يستدعي وظيفة المسجل.	3	3	Deny-by-default RBAC وصلاحيات قاعدة بيانات محدودة.
SQL Injection	مدخل بحث يغيّر الاستعلام.	2	3	عزل LAB Schema واستخدام Prepared Statements.

7. Data Classification

التصنيف	أمثلة	الحماية
Public	دليل المقررات المعتمد للنشر.	النشر بعد الموافقة.
Internal	إجراءات العمل والإعدادات الداخلية.	للموظفين المصرح لهم.
Sensitive	بيانات الطلبة والتسجيلات والعلامات والبيانات الشخصية.	صلاحيات حسب الدور وحماية أثناء النقل والتخزين.
Restricted	Password Hashes وSecrets وKeys.	أقل صلاحية وعدم رفع الأسرار إلى Git.

8. خطة العمل ومخرجات المرحلة

المهمة	المخرج
تحليل المتطلبات والأدوار وقواعد العمل.	Requirements Document
تصميم الجداول والحقول والعلاقات والقيود.	ERD
تحديد مكونات النظام وتدفق البيانات وحدود الثقة.	Architecture Diagram & DFD
تحديد التهديدات وتقدير المخاطر وضوابطها.	STRIDE Threat Model
تنظيم ملفات المشروع وتعليمات التشغيل.	Git Repository & README

خطة الإصدارات

Milestone	المحتوى
M1	Analysis & Design
M2	System Development
M3	Security Implementation
M4	Final Report & Demonstration

9. تنظيم Git Repository

```
project-root/
├── README.md
├── .env.example
├── backend/
├── frontend/
├── db/ (SQL scripts)
├── lab/
└── docs/
```

يوضح README.md متطلبات التشغيل وإعداد قاعدة البيانات وترتيب ملفات SQL وطريقة تشغيل النظام. لا تُرفع كلمات المرور أو المفاتيح أو البيانات الحقيقية إلى المستودع.

10. M1 Submission Checklist

- متطلبات FR01–FR12 والأدوار وBusiness Rules.
- ERD بالجداول والحقول والمفاتيح والعلاقات والقيود.
- Architecture Diagram وDFD مع حدّي ثقة.
- STRIDE بستة تهديدات على الأقل مع الاحتمالية والأثر والضوابط.
- إضافة الملفات وREADME إلى Git Repository.
- حفظ التعديلات في Commit وإنشاء Git Tag باسم M1.